

This chapter covers the following topics related to Objective 4.2 (Summarize various types of attacks and their impact to the network) of the CompTIA Network+ N10-009 certification exam:

- Denial-of-service (DoS)/distributed denial-of-service (DDoS)
- VLAN hopping
- Media Access Control (MAC) flooding
- Address Resolution Protocol (ARP) poisoning
- ARP spoofing
- DNS poisoning
- DNS spoofing
- Rogue devices and services
  - DHCP
  - AP
- Evil twin
- On-path attack
- Social engineering
  - Phishing
  - Dumpster diving
  - Shoulder surfing
  - Tailgating
- Malware

Types of Network Attacks

Have you ever heard the expression "Know your enemy"? It is a very fitting expression for this chapter, which focuses on the attacks that are very common in today's networked environment. And while you might think that all network attacks focus deeply on technology, remember that many attacks focus on the human element. As you will learn later in this chapter, we call attacks leveraging the human social engineering attacks.

It is important to note that many of the successful security attacks carried out against a wide variety of organizations are successful because they involve using multiple attack types in strategic ways. Very successful cybercriminals realize that they can use specific attacks to achieve specific goals as part of an overall strategy.

Foundation Topics

Technology-Based Attacks

When you think about cybersecurity attacks, you are likely to think about attacks that make use of technology. After all, you are in the field of technology. But these are not the only attacks that affect networks. Social engineering attacks are also a major problem today and are often the first step in more sophisticated attacks that take place. Before we launch into a look at these social engineering attacks, let's take a detailed look at a variety of common technology-based attacks.

Key Topic

Denial-of-Service (DoS)

An attacker can launch a ***denial-of-service (DoS)*** attack on a system by sending the target system a flood of data or requests that consumes the target system's resources. In addition, some operating systems and applications crash when they receive specific strings of improperly formatted data, and the attacker can leverage such OS/application vulnerabilities to render a system or an application inoperable. The attacker often uses IP spoofing to conceal their identity when launching a DoS attack, as illustrated in Figure 19-1.

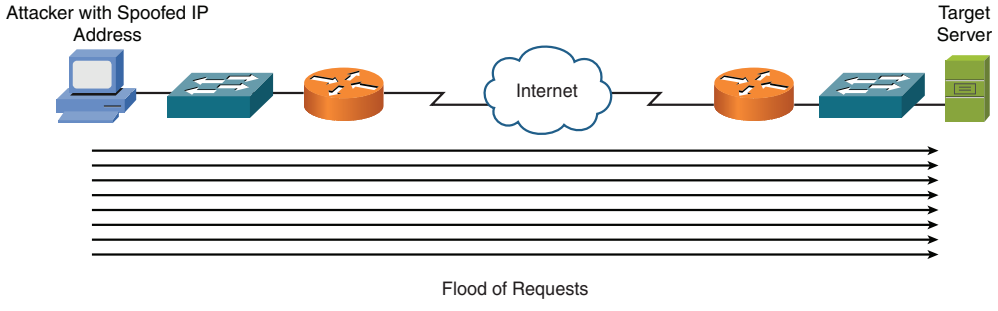


Figure 19-1 DoS Attack

DoS attacks are often categorized as follows:

- **Reflective:** A third-party system is used to help carry out this type of attack. Often this third party is not compromised, which makes a reflective attack very difficult to track down.
- **Amplified:** A DNS server is often used in an amplification attack, but other services could be used in such an exploit as well. With these attacks, legitimate servers are tricked into flooding responses at a target system; the forged

request tends to be small but results in large responses hitting the target. It can be difficult to mitigate amplified attacks because the server involved (called the *reflector server*) is a legitimate device.

Distributed Denial-of-Service (DDoS)

Key Topic

A ***distributed denial-of-service (DDoS)*** attack builds upon the DoS attack and makes it one of the most feared of all the attacks that exist. These attacks can dramatically increase the amount of traffic flooded to a target system. A DDoS attack is a coordinated attack. Specifically, an attacker compromises multiple systems and then instructs those compromised systems, called *zombies or bots*, to simultaneously launch a DDoS attack against a target system. The attacker uses *command and control* software to instruct the zombies to do their job. These zombies are even scarier than the ones in *The Walking Dead* because they are remotely controlled.

NOTE A *botnet* is an entire network segment that is filled with bots.

A significant traffic spike (as compared to the baseline) could provide an early indication that a DDoS attack is taking place. An intrusion prevention system (IPS) is designed to recognize and alert when attacks or malicious traffic is present on a network.

NOTE Remember that a DoS attack originates from a single system, whereas a DDoS attack originates from multiple systems simultaneously and the attacker distributes zombie software or infects multiple (even into the thousands) hosts, providing the attacker partial or full control of the infected computer system through one or more command and control servers. Finally, the army of bots or compromised machines attacks the victim by overwhelming it, making it slow to respond or unable to respond to legitimate requests.

On-Path Attack

An attacker who can get in the direct path between a client and a server can then eavesdrop on the conversation between the client and the server; this type of attack is called an ***on-path attack***. This attack used to go by the name of a man-in-the-middle attack.

If cryptography is being used and the attacker fools the client and server both into building VPNs to the attacker instead of to each other, the attacker can see all the data in plaintext. On a local Ethernet network, methods such as Address Resolution

Protocol (ARP) spoofing, ARP cache poisoning, Dynamic Host Configuration Protocol (DHCP) spoofing, and Domain Name System (DNS) spoofing and poisoning may be used to redirect a client's traffic through the attacker instead of directly to the server.

NOTE The newer terminology *on-path attack* is much more accurate than the older term *man-in-the-middle attack*, which does not properly convey that the attacker can carry out an attack from any point on the path (not just the middle).

DNS Poisoning

Another potential for attacks against cybersecurity involves the DNS service and systems, and many advancements have therefore been made in DNS security mechanisms. One simple approach to DNS attacks is the injection of false entries into the DNS system, known as ***DNS poisoning***. This might be done in order to deny service to systems or to redirect them to websites that might be designed to disseminate malware or collect credentials. DNS poisoning is also known as ***DNS spoofing***, hijacking, or redirection.

VLAN Hopping

802.1Q trunk links support a feature called Q-in-Q tunneling. This approach, which involves encapsulating 802.1Q traffic inside other 802.1Q traffic, can be very beneficial for service providers that might take trunk traffic from customers and need to tunnel that traffic through their own service provider trunks.

Unfortunately, the use of a native VLAN can be exploited with this Q-in-Q tunneling technology. Specifically, an attacker can use the combination of Q-in-Q tunneling and the native VLAN feature to send traffic into a VLAN that the attacker would not normally be able to send traffic into. This type of attack is called ***VLAN hopping***.

Common security changes to prevent VLAN hopping attacks include ensuring that the native VLAN is set to a completely unused VLAN or, for switches that support it, tagging the native VLAN. Both measures eliminate VLAN hopping attacks.

ARP Poisoning

In an ***Address Resolution Protocol (ARP) poisoning*** attack, the attacker changes the MAC address table to contain incorrect entries. Oftentimes, this is done to redirect traffic to the attacker, allowing them to eavesdrop on communications, capture

sensitive data like login credentials, inject malicious data, or even disrupt network services.

ARP Spoofing

As you might expect, ***ARP spoofing*** involves falsifying identity. With ARP spoofing, the attacker misrepresents the Layer 2 MAC address. An attacker might use MAC spoofing to bypass simple MAC-based security mechanisms, such as port security.

Rogue DHCP

Rogue DHCP servers might be accidental or malicious in a network. When they are malicious, the attacker is seeking to disrupt (or redirect) end-user traffic by providing false DHCP leased IP address information.

Today, DHCP snooping provides excellent protection against such attacks. This technology seeks to ensure that DHCP server traffic is legitimate in the network at all times.

Rogue Access Point

Rogue access points are unauthorized access points (APs) that prevent legitimate network access through intentional misconfiguration. This approach is very similar to the rogue DHCP server approach.

Evil Twin

As you learned in Chapter 11, "Configure Wireless Devices and Technologies," an ***evil twin*** is a special type of rogue access point attack. An evil twin attack is designed to capture authentication information from an unsuspecting network user. This attack is so named because a rogue AP is configured in this scenario to appear just like the legitimate AP that the client should be connecting with.

Ransomware

Ransomware has been an extremely popular type of cybersecurity attack for the past several years. With this style of exploit, the attacker locks access to a system or files (often using encryption) or at least pretends to have locked access. The attacker demands the computer user to pay a ransom to get the system or files unlocked. Attackers commonly require the ransom to be paid in bitcoin or some other cryptocurrency to make the attack less traceable.

Password Attacks

For as long as computer systems have existed, *password attacks* have also existed. With this type of attack, the attacker seeks to gain access to systems or files by using the actual password required for that access. There are many different forms of password attacks, including the following:

- **Brute-force password attack:** In this type of attack, the attacker tries all possible password combinations until a match is made. For example, a brute-force attack might start with the letter a and go through the letter z, and then the attacker might attempt the letters aa through zz, continuing to try combinations until the password is determined. Using complicated passwords—with a mixture of upper- and lowercase letters as well as special characters and numbers—can help prevent brute-force attacks.
- **Dictionary password attack:** In this type of attack, the attacker tries multiple password guesses. However, a dictionary attack is based on a dictionary of commonly used words rather than trying all possible combinations, as in a brute-force attack. Picking a password that is not a common word helps thwart dictionary attacks.

MAC Spoofing

MAC spoofing is a simple attack in which a cybercriminal pretends to possess a different MAC address than is actually on the criminal's system. MAC spoofing is often the first step in a much larger and more sophisticated attack. Because MAC spoofing is relatively easy to accomplish, port security is not often viewed as a sophisticated and comprehensive defense in a network. More sophisticated security solutions, such as dynamic ARP inspection (DAI), are more robust and more effective mechanisms to mitigate issues like MAC spoofing in the network.

MAC Flooding

A ***Media Access Control (MAC) flooding*** attack is a network-based exploit in which an attacker overwhelms a network switch by sending many packets with spoofed MAC addresses. The attacker does this to cause the switch's MAC table to exceed its capacity. Once the table is full, the switch is forced to direct traffic out all ports. This results in severe network performance degradation and creates a significant security vulnerability, as sensitive data intended for specific devices is broadcast across the entire network. This makes it easier for the attacker to intercept and capture sensitive information, facilitating further attacks such as eavesdropping, data theft, or on-path attacks.

IP Spoofing

It did not take long in the history of TCP/IP and the Internet for attackers to realize that they could fool many IP security mechanisms by simply pretending to possess a different IP address. Think about how many security mechanisms (such as access control lists [ACLs]) focus on the IP address that a source of traffic is using. Faking this address is often all that is required to breach an IP address-based security solution.

It is relatively easy to modify a source IP address, but there are many mechanisms you can use in modern networks to guard against *IP address spoofing*. One Cisco solution is IP Source Guard, which is a tool that relies on DHCP snooping and coordinates DHCP-assigned IP addresses to systems in a network based on the MAC addresses of those systems.

Deauthentication

In a *deauthentication* attack, the attacker sends a deauthentication frame to the victim to disconnect that client from the wireless LAN. While continuously disconnecting a client from Wi-Fi would do a great job frustrating the end user (and the local help desk), it would not in and of itself cause much damage. Typically, the attacker carries out further attacks against the client. For example, an attacker who has installed an evil twin on the network might first carry out a deauthentication attack and then, when the client is reconnecting to the network, attempt to ensure that the end user connects to the evil twin.

Malware

Malware has become a catchall term for the various types of viruses, worms, spyware, Trojans, and other problematic and malicious software or code on a network. Malware can vary from a mere inconvenience to a catastrophic type of security incident. For example, after a single machine in an organization is compromised and is running malicious software, the attacker might use that single computer to proceed further into the internal network and use the compromised host as a pivot point.

Malware in your organization may have been implemented by an outside attacker or by an inside disgruntled employee. Antivirus and anti-malware software should be run on all systems, and users should be given very limited rights related to installation of any software on the computers they use.

Key Topic Social Engineering Attacks

Attacks that leverage human nature and human behavior are called ***social engineering*** attacks. These types of attacks are very common and are often the first step or steps in much larger attacks. The following are some specific types of social engineering attacks:

- ***Phishing*:** This variation of a social engineering attack involves sending an email to a user that appears to be legitimate in an attempt to have that user input authentication information that is then captured. For example, the email may ask the reader to click a website link to claim a package from FedEx. The attacker constructs a website at the false address that looks just like the actual FedEx website.
- ***Tailgating*:** With tailgating, the attacker physically follows a valid employee through a secured area of the organization. For example, the attacker might notice that a security badge swipe opens a door and that the door, once opened, does not lock again for 30 seconds. The attacker will wait for a valid entry and then sneak into the area after that entry and before 30 seconds have elapsed. An access control vestibule, formerly known as a mantrap, is a physical access control system consisting of a small area and two interlocking doors used to prevent tailgating.
- **Piggybacking:** Piggybacking is similar to tailgating and, in fact, the two terms are often used interchangeably. However, piggybacking is often distinguished from tailgating in that the valid employee knows and is cooperating with the cybercriminal. In addition, the term *piggybacking* is used to refer to a purely electronic transaction. In this form of piggybacking, data flows through some key point in the network, and while that channel is open, the criminal sneaks their data through. As previously noted, access control vestibules are implemented to stop piggybacking/tailgating.
- ***Shoulder surfing*:** In this classic form of social engineering attack, the cybercriminal simply watches over the shoulder of an authorized employee to learn passwords and other inputs to gain access at a later time. In addition, a shoulder surfer might look for sensitive information such as employees' Social Security numbers on the screen of an HR employee. Special screen filters are available for computer displays and ATMs to prevent someone from shoulder surfing or seeing the screen at an angle.
- ***Dumpster diving*:** Dumpster diving is an attack where individuals scavenge through trash or discarded materials to extract sensitive information that can be used for malicious purposes, such as identity theft or corporate espionage. Attackers target dumpsters or trash bins near homes, businesses, and public

places to retrieve documents, old computers, or storage devices that may contain confidential data like financial records, passwords, personal details, or proprietary business information. This method exploits the tendency of individuals and organizations to improperly dispose of sensitive items.

Other Miscellaneous Attacks

Table 19-1 describes other miscellaneous types of attacks that you need to be familiar with in today's networked environment.

Table 19-1 Miscellaneous Attacks

Attack	Description
Packet capture	An attacker can use a packet capture (or *packet sniffing*) utility such as Wireshark (https://wireshark.org) to capture packets after placing a PC's network interface card (NIC) in promiscuous mode. Some protocols, such as Telnet and HTTP, are sent in plaintext, which means packets sent with these protocols can be read by an attacker, perhaps allowing the attacker to see confidential information.
Confidentiality attacks (ping sweep and port scan)	A confidentiality attack might begin with a scan of network resources to identify attack targets on a network. A ping sweep could be used to ping a series of IP addresses. Ping replies might indicate to an attacker that network resources were reachable at those IP addresses. After a collection of IP addresses is identified, the attacker might scan a range of UDP or TCP ports to see what services are available on the hosts at the specified IP addresses. Also, port scans often help attackers identify the operating system running on a target system. These attacks are also commonly referred to as *reconnaissance attacks*.
Electromagnetic interference (EMI) interception	Data is often transmitted over wires (for example, unshielded twisted pair), and attackers can sometimes copy information traveling over a wire by intercepting the EMI *emanations* being emitted by the transmission medium. A government project called Tempest studied the ability to understand the data traveling through a network by listening to emanations. A Tempest room is designed to keep emanations contained within that room to increase the security of data communications happening there.
Wiretapping	An attacker who gains physical access to a wiring closet might physically tap into telephone cabling to eavesdrop on telephone conversations or might insert a shared media hub inline with a network cable to connect to the hub and receive copies of packets flowing through the network cable.

Attack	Description
Information sent over overt channels	An attacker might send or receive confidential information over a network by using an *overt channel*. An example of using an overt channel is tunneling one protocol inside another (for example, sending instant-messaging traffic via HTTPS). Steganography is another example of sending information over an overt channel. For example, an attacker might send a digital image made up of millions of pixels with secret information encoded in specific pixels, where only the sender and the receiver know which pixels represent the encoded information.
Information sent over covert channels	An attacker might send or receive confidential information over a network by using a covert channel, which can communicate information as a series of codes/events. For example, an attacker could represent binary data by sending a series of pings to a destination. A single ping within a certain period of time could represent a binary 0, and two pings within that same time period could represent a binary 1.
FTP bounce	FTP supports a variety of commands for setting up a session and managing file transfers. An attacker may use one of these commands, the **port** command, to access a system that would otherwise deny the attacker. Specifically, an attacker connects to an FTP server by using the standard port 21. However, FTP uses a secondary connection to send data. The client issues a **port** command to specify the destination port and destination IP address for the data transmission. Normally, the client would send its own IP address and an ephemeral port number. The FTP server would then use the source port 20 and the destination port specified by the client when sending data to the client. However, an attacker might issue a **port** command specifying the IP address of a device to access, along with an open port number on that device. As a result, the targeted device might allow an incoming connection from the FTP server's IP address but reject a connection coming in from the attacker's IP address. Fortunately, most modern FTP servers do not accept the **port** command coming from a device that specifies a different IP address than the client's IP address.
Session hijacking	An attacker could hijack a TCP session, for example, by completing the third step in the three-way TCP handshake process between an authorized client and a protected server. An attacker who successfully hijacks the session of an authorized device might be able to maliciously manipulate data on the protected server.
Salami attack	A salami attack is a collection of small attacks that result in a larger attack when combined. For example, an attacker who has a collection of stolen credit card numbers could withdraw small amounts of money using each credit card, and the combination of the multiple small withdrawals would add up to a significant sum for the attacker.

Attack	Description
Data diddling	Data diddling involves changing data before it is stored in a computing system. Malicious code in an input application or a virus could perform data diddling. For example, a virus, Trojan horse, or worm could be written to intercept keyboard input, and while the appropriate characters are displayed onscreen (so that the user does not see an issue), manipulated characters could be entered into a database application or sent over a network.
Trust relationship exploitation	Different devices in a network might share a trust relationship. For example, a certain host might be trusted to communicate through a firewall using specific ports, while other hosts are denied passage through the firewall using those same ports. If an attacker were able to compromise the host that had a trust relationship with the firewall, the attacker could use the compromised host to pass normally denied data through a firewall.
Logic bomb	In this type of attack, malicious code is hidden in a system and can be triggered by the author or by another attacker. For example, a programmer might hide malicious code that starts deleting files if the programmer's employment is terminated.
TCP SYN flood	In this variant of a DoS attack, an attacker initiates multiple TCP sessions by sending SYN segments but then never completing the three-way TCP handshake. The attacker can send multiple SYN segments to a target system with false source IP addresses in the header of the SYN segments. Because many servers limit the number of TCP sessions they can have open simultaneously, a SYN flood can render a target system incapable of opening a TCP session with a legitimate user.
Buffer overflow	A computer program may be given a *buffer*, which is a dedicated area of memory to which it can write. If the program attempts to write more information than the buffer can accommodate, a buffer overflow may occur. If permitted to do so, the program can fill up its buffer and then have its output spill over into the memory area being used for a different program. This can potentially cause the other program to crash. Some programs are known to have this vulnerability (that is, be able to overrun their memory buffers), which can be exploited by attackers.
ICMP attack	Many networks permit the use of Internet Control Message Protocol (ICMP) traffic (for example, ping traffic) because pings can be useful for network troubleshooting. However, attackers can use ICMP for DoS attacks. One ICMP DoS attack variant, called the *ping of death*, uses ICMP packets that are too big. Another variant sends ICMP traffic as a series of fragments in an attempt to overflow the fragment reassembly buffers on the target device. Also, a *Smurf attack* can use ICMP traffic directed to a subnet to flood a target system with ping replies.

Attack	Description
Electrical disturbance	At a physical level, an attacker may launch an availability attack by interrupting or interfering with the electrical service available to a system. For example, an attacker who gains physical access to a data center's electrical system might be able to cause a variety of electrical disturbances, such as power spikes, electrical surges, blackouts, and brownouts.
Supply chain attack	This type of attack takes advantage of the weakest cybersecurity link and often begins with an advanced persistent threat (APT) during the manufacturing process of an electronic or digital product in order to ultimately cause harm to a target customer or company.
Cryptojacking	In this attack, criminals use malware to deliver malicious cryptomining software in order to use distributed resources of others (often as part of a botnet) to mine for cryptocurrency.
Keylogger trojans	Keylogger trojans monitor and send keystrokes typed from an infected machine.
Advanced persistent threat (APT)	APTs are a "low and slow" style of attack executed to infiltrate a network and remain inside while going undetected.
Fileless malware	This attack works similarly to a memory-resident virus but is more insidious. While the latter still requires some components of the virus to be written to disk, a fileless virus does not.
Birthday attack	A birthday attack is a cryptographic method of attack against a secure hash. It is based on what is known as the birthday paradox.
Downgrade attack	The downgrade attack is often a result of security configurations not being updated. Often this stems from the desire to maintain backward compatibility.
Password spraying	Password spraying is an attack that attempts to access a large number of user accounts with a very few number of commonly used passwords.
Skimming	Skimming essentially copies data from the card (ATM or other) using a specialized terminal. As a result, the card can subsequently be cloned by taking a blank card and encoding the stolen data.
USB drop attack	A USB drop attack occurs when an attacker drops USB flash drives loaded with malware in a public place in the hopes the target will pick it up and, out of curiosity, plug it into a system to see what's on it. Once plugged in, the malware can automatically run and infect the system. This can be mitigated by enabling Turn Off AutoPlay in the Windows Local Group Policy Editor AutoPlay Policies settings.
SQL injection attack	A SQL injection attack is malicious code that is inserted into strings that are later passed to a database server. The SQL server then parses and executes this code.

Attack	Description
LDAP injection attack	The LDAP injection attack is similar to the SQL injection attack, but instead malicious input is applied to a directory server, which may result in unauthorized queries, granting of permissions, and even password changes.
Privilege escalation	This attack occurs when an attacker is able to gain elevated access to areas that otherwise should be restricted.
Bluejacking	This attack occurs when Bluetooth-enabled smart devices receive photos, messages, or other file broadcasts sent from a nearby Bluetooth-enabled transmitting device.
Bluesnarfing	A bluesnarfing attack is a type of unauthorized access where an attacker exploits a Bluetooth-enabled device to steal sensitive information, such as contacts, messages, and other data, without the device owner's knowledge. Notice that this is a more aggressive attack than bluejacking.

NOTE The attack types listed in this chapter are just some of the many attack types being used today. New attacks and even new categories of attacks are being created all the time. Also, keep in mind that many attacks are actually perpetrated by employees of an organization. They are called *insider attacks*.

Real-World Case Study

Acme, Inc. has recognized the growing threat landscape and decided to enhance its security training for both IT staff members and all end users across the organization. This comprehensive approach acknowledges that cybersecurity is a shared responsibility and aims to equip everyone with the necessary skills to protect the organization against emerging threats. By focusing on tailored training sessions for different groups, Acme, Inc. ensures that both technical and non-technical employees are well prepared to respond to various security challenges.

The decision to prioritize social engineering in the training for end users highlights the company's awareness of the increasing sophistication of such attacks. Social engineering, particularly phishing, remains one of the most common and effective tactics used by cybercriminals to breach organizational defenses. As the organization has experienced a rise in successful phishing attempts, the training will specifically address these threats, teaching end users how to recognize and respond to phishing attempts, thereby reducing the likelihood of successful attacks.

For the IT staff, Acme, Inc. is implementing ongoing training that not only covers social engineering but also dives deep into the latest advancements in cybersecurity threats. The focus on continuous education ensures that the IT team stays ahead of the curve, with particular attention to detecting and mitigating distributed denial-of-service (DDoS) attacks. Given the potential damage that DDoS attacks can cause, the training will emphasize rapid detection at the network perimeter, enabling the IT staff to respond swiftly and minimize disruption to the organization's operations.

By dedicating resources to both end-user and IT staff training, Acme, Inc. is taking a proactive stance against cyber threats. The company understands that while technical defenses are essential, human error remains a significant vulnerability. Therefore, empowering employees with knowledge and awareness is a critical component of the organization's overall cybersecurity strategy.

This dual-focused training approach not only strengthens the immediate defenses against specific threats like phishing and DDoS attacks but also fosters a culture of security awareness throughout the organization. As a result, Acme, Inc. is better positioned to handle current and future challenges, ensuring the security and resilience of its operations.

Summary

Here are the main topics covered in this chapter:

- This chapter described some of the most common technology-based security attacks.
- This chapter described some of the most common human-based attacks.
- This chapter described some of the common miscellaneous attacks that may be carried out against a network.

Exam Preparation Tasks

Review All the Key Topics

Review the most important topics from this chapter, noted with the Key Topic icon in the outer margin of the page. Table 19-2 lists these key topics and the page number where each is found.

Key Topic

Table 19-2 Key Topics for Chapter 19

Key Topic Element	Description	Page Number
Section	Denial-of-Service (DoS)	458
Section	Distributed Denial-of-Service (DDoS)	459
Section	Social Engineering Attacks	464

Define Key Terms

Define the following key terms from this chapter and check your answers in the Glossary:

Address Resolution Protocol (ARP) poisoning, ARP spoofing, denial-of-service (DoS), distributed denial-of-service (DDoS), DNS poisoning, DNS spoofing, dumpster diving, evil twin, logic bomb, malware, Media Access Control (MAC) flooding, on-path attack, phishing, rogue access point, rogue DHCP server, shoulder surfing, social engineering, tailgating, VLAN hopping

Additional Resources

The Cyber Kill Chain for Aspiring Ethical Hackers: https://www.youtube.com/watch?v=HVwI1KbrhOU

What Is a Cyberattack?: https://www.cisco.com/c/en/us/products/security/common-cyberattacks.html

Review Questions

The answers to these review questions appear in Appendix A, "Answers to Review Questions."

1. Which type of attack exploits the native VLAN of 802.1Q?
   a. Evil twin
   b. Tailgating
   c. Deauthentication
   d. VLAN hopping

2. In what type of attack does the attacker compromise multiple systems and then instruct those compromised systems, called *zombies*, to simultaneously flood a target system with traffic?
   a. DoS attack
   b. TCP SYN flood attack
   c. Buffer overflow
   d. DDoS attack

3. Which of the following is an example of a social engineering attack?
   a. DDoS attack
   b. DoS attack
   c. Tailgating
   d. On-path attack

4. In what type of attack does the attacker try all possible password combinations until a match is made?
   a. Dictionary attack
   b. MAC spoofing
   c. IP spoofing
   d. Brute-force attack

5. What type of attack often seeks payment in bitcoin or other cryptocurrency?
   a. Malware
   b. DDoS
   c. Ransomware
   d. DNS poisoning

6. What type of attack originates from multiple systems simultaneously?
   a. DoS
   b. DDoS
   c. VLAN hopping
   d. Media Access Control (MAC) flooding

7. Which of the following is a type of rogue access point attack designed to capture authentication information from an unsuspecting network user?
   a. Address Resolution Protocol (ARP) poisoning
   b. Brute-force
   c. Dictionary
   d. Evil twin

8. Which of the following is not considered a type of social engineering attack?
   a. Shoulder surfing
   b. Dumpster diving
   c. Phishing
   d. Password spraying